WEB SECURITY LAB 2

OWASP & WEB SECURITY RISKS

(2017 MALAYSIA DATA BREACH)



UTHM

اونيۏرسيتي تون حسين عون مليسيا

Universiti Tun Hussein Onn Malaysia

COURSE CODE:	**BIS20303**
COURSE NAME:	**WEB SECURITY**
STUDENT NAMES:	1. **MUHAMMAD SYAZUAN BIN SANOSI (CI250056)** 2. **MUHAMMAD QAYYUM BIN SAIFUL NIZAM (CI250045)** 3. **FAIQ LUQMAN BIN MOHAMED (CI250067)** 4. **MUHAMMAD FARISH BIN NORMESHAM (CI250131)**
SECTION:	**SECTION 1**
SEMESTER:	**SEMESTER 1 2026/2027**
LECTURER:	**ENCIK KHAIRUL AMIN BIN MOHAMAD SUKRI**

1.0 Introduction to OWASP

Currently, web applications are widely used for banking, communication, education, shopping, and managing personal information. However, they may contain security vulnerabilities that attackers can exploit to steal data or disrupt services. The Open Worldwide Application Security Project (OWASP) provides guidelines to help developers reduce these risks, especially through its well-known OWASP Top 10, which highlights major web application security risks [1].

1.1 Overview of OWASP

OWASP (Open Worldwide Application Security Project) is a nonprofit foundation that provides free tools, guidelines, and educational resources to improve software and web application security. It helps developers and organizations identify vulnerabilities and practice secure coding [1].

OWASP is important because web applications store sensitive information, such as passwords, personal details, and financial records. Its resources help prevent cyberattacks, protect data, reduce security risks, and increase user confidence [1].

1.2 Purpose of OWASP Top 10

The OWASP Top 10 is a standard awareness document that identifies ten of the most important categories of web application security risks. It is designed to help understand common vulnerabilities and which security features should be prioritized for an application. The OWASP Top 10 helps organizations in several ways [1].

First, it raises awareness of common security risks that may affect web applications. Understanding these risks allows developers to recognize potential weaknesses during software development so they could avoid them [1].

Second, it supports secure coding practices by highlighting vulnerabilities that should be considered when designing, developing and testing applications [1].

Third, it helps organizations prioritize security testing and reducing or reversing damages [1].

Finally, it provides a shared reference for developers, security testers and management to discuss application security using consistent terminologies [1].

1.3 OWASP Frequency of Updates and Reasons For Changes

From our research, the OWASP Top 10 is updated periodically rather than on a fixed schedule. Previous editions were published in 2003, 2004, 2007, 2010, 2013, 2017, 2021 and 2025 [1]. The categories change because cybersecurity threats, software technologies and development practices continue to change or evolve every year. New vulnerabilities and threats will emerge and existing weaknesses will become more widely understood and attackers will undoubtedly develop new tools and techniques to exploit an application.

OWASP uses application security data and feedback from industry professionals to identify the important risks and find out how the categories should be organized. For example, the 2025 edition introduced the Software Supply Chain Failures as a category of Server-Side Request Forgery (SSRF) into Broken Access Control. It also changed and reorganized categories to put a highlight on the underlying causes of security weaknesses instead of only their consequences [1]. Therefore, these updates help organizations to maintain relevant security practices and

understand the risks that are currently affecting modern applications.

2.0 Selected OWASP Security Risk & Detailed Analysis

Selected Risk: Broken Access Control

Our selected risk is Broken Access Control and it is ranked #1 in the OWASP Top 10 (2021 and 2025 editions), making it the most critical web application security risk today. It occurs when users do not have proper restrictions on what they are allowed to access or perform beyond their intended permissions [2].

2.1 Risk Description

Broken Access Control refers to vulnerabilities that allow attackers to bypass authorization checks and act as another user, access restricted functionality, or view sensitive data they should not be permitted to see. For example, a regular user might be able to access an admin-only page, view another user's private records, or modify someone else's account details simply by changing a URL parameter or request value.

Access control ensures users can only operate within the scope of their assigned privileges. When these checks are missing, flawed, or not enforced on the server side, the system is vulnerable [2].

2.2 How It Happens

Exploitation method	**Description**
Parameter tampering	Changing values like "user_id " in a URL to access other users' records
Missing API Controls	Unprotected POST/PUT/DELETE endpoints accepting any request without verification
URL Guessing	Guessing or enumerating URLs to reach privileged or authenticated pages

2.3 Prevention Measures

Practice	**Description**
Implement once, reuse everywhere	Build a centralized authorization mechanism and apply it consistently across the entire application.
Secure session management	Invalidate session identifiers on the server after logout. Use short-lived JWT tokens.
Enforce access control only in trusted server-side code	We never rely on client-side checks. The attacker must not be able to modify the authorization logic or the metadata itself

3.0 Real-World Case Study: Malaysia Telecommunication Data Breach

3.1 Details of The Incident

In October 2017, Malaysia experienced a major personal data leak involving 46.2 million mobile subscriber records. The incident was reported by Malaysian news outlets after personal information was reportedly found available for sale online [3].

According to *The Star*, the leaked information included subscribers' names, MyKad identification numbers, addresses, telephone numbers, and SIM card information. The reported number of records exceeded Malaysia's population because individuals could own multiple mobile numbers, and the data reportedly included inactive and temporary numbers [3].

The Malaysian Communications and Multimedia Commission (MCMC) met with telecommunications companies and cooperated with the police to investigate the incident. At the time, authorities had not publicly established the precise source and circumstances of the leak. Reports also suggested that the data might have originated from a breach dating back to 2014 [3] [4].

3.2 How Does The Incident Relate To The Selected OWASP Risk

The incident shows what happens when one fails to protect a large amount of sensitive personal information. If unauthorised individuals were able to access subscriber databases or backup files due to lack of access checking, it is a clear demonstration of Broken Access Control [2].

For example, a database without proper restriction could allow unauthorised accounts to retrieve subscriber data. Similarly, excessive privileges or lack of restrictions on data exports could allow a user or a compromised account to access information beyond its legal capabilities [2].

The leaked data also created risks of identity misuse, phishing, impersonation and social engineering as criminals could use genuine personal details to make fraudulent communication appear credible [3].

3.3 Risk Reduction and Prevention

Several measures could have been taken to reduce or prevent the same incident from repeating [2]:

- Strict access permissions: Limit access to subscriber databases to authorised employees and approved applications.
- Least privilege access: Prevent individual accounts and services from retrieving more records than necessary.
- Database access monitoring: Record and investigate unusually large queries, bulk reports and suspicious access attempts.
- Secure data transfers and backups: Protect subscriber information throughout storage, export and transfer processes.
- Regular security audits: Test database permissions, application authorisation controls and access to sensitive files.

REFERENCES

[1] OWASP Foundation, “OWASP Top 10:2025—Introduction,” *OWASP Top 10*, 2025. [Online]. Available: https://top10.owasp.org/2025/0x00_2025-Introduction/. [Accessed: Oct. 15, 2026].

[2] OWASP Foundation, “A01:2025—Broken Access Control,” *OWASP Top 10*, 2025. [Online]. Available: https://top10.owasp.org/2025/A01_2025-Broken_Access_Control/. [Accessed: Oct. 15, 2026].

[3] The Star, “M’sia sees biggest mobile data breach,” *The Star*, Oct. 31, 2017. [Online]. Available: https://www.thestar.com.my/news/nation/2017/10/31/msia-sees-biggest-mobile-data-breach-over-46-million-subscribed-numbers-at-risk-from-sca. [Accessed: Oct. 15, 2026].

[4] Malay Mail, “Probe into data breach ongoing, deputy minister tells Dewan Rakyat,” Mar. 14, 2018. [Online]. Available: https://www.malaymail.com/news/malaysia/2018/03/14/probe-into-data-breach-ongoing-deputy-minister-tells-dewan-rakyat/1598129. [Accessed: Oct. 15, 2026].